

ESCOLHA CERTA • REVISÃO AMPLIADA

Relatório de Auditoria de Segurança — Escolha Certa

OWASP Top 10:2025 + mass assignment, IDOR, CSRF, XSS, path traversal, SSRF e DoS

30 de setembro de 2026 | pt-BR

Escopo ampliado

Java 17, Spring Boot/MVC/Security, JPA/Hibernate, MySQL/Flyway, Thymeleaf e Docker. Revisão de todos os 31 handlers MVC (37 combinações método/padrão), entradas, saídas, autorização, storage, configurações e scripts. A aplicação permaneceu inalterada.

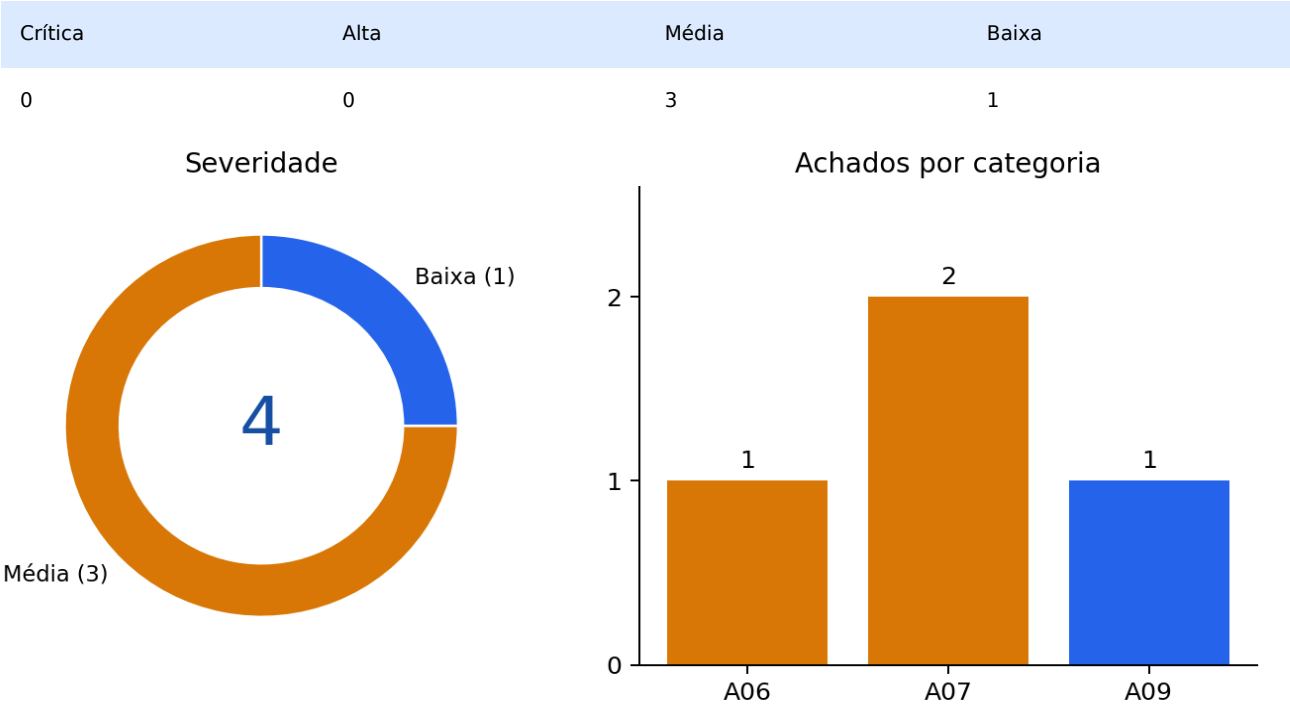
Nota metodológica

As categorias OWASP foram adaptadas à stack: autorização por filtro Security; binding por DTOs; consultas JPA; escape Thymeleaf; sessões e BCrypt; upload ImageIO/UUID; limites e observabilidade. Este complemento amplia a auditoria anterior de cinco categorias. A revisão estática e provas de lógica isoladas não substituem pentest ou homologação da nuvem.

Resumo executivo

4 achados: 3 médios e 1 baixo

Os novos achados são de autenticação, resistência a abuso e trilha de auditoria. Não foi comprovado acesso sem ADMIN, IDOR privado, mass assignment, XSS, SQLi, command injection ou travessia de caminhos. O resultado não garante ausência de outras falhas.



Prioridades

P1: fortalecer limitação do login e política de senhas; conferir o ingresso da nuvem. P2: limitar consultas públicas, estabelecer orçamento de GET e registrar o autor das alterações. P3: árvore Maven/SBOM/scanner de dependências, histórico Git e artefato final.

Limitações materiais

- O projeto entregue não contém .git; git log falhou. Histórico de commits e segredos removidos não puderam ser auditados.
- Não há JAR/bundle compilado ou source maps. Foram examinados todos os assets de frontend entregues: site.js, site.css e 25 templates.
- Maven, Docker e MySQL indisponíveis neste ambiente. Não houve execução da aplicação, suíte JUnit, pentest HTTP ou inspeção do banco em execução.
- Não foram inspecionados .env do computador do usuário, secrets de nuvem, proxy, IAM, buckets ou pipeline externa. Não há CI, Helm ou Terraform no pacote.
- Sem resolução Maven ou varredura CVE das dependências transitivas; esses controles estão fora das cinco categorias solicitadas.

Matriz das dez categorias OWASP

DDoS não é resolvido somente com código. A análise cobre abuso de recursos da aplicação; rede, CDN/WAF, capacidade e ataques volumétricos dependem do provedor.

Categoria	Resultado / evidência
A01 - Broken Access Control	Sem falha nova verificada 31 handlers/37 padrões revistos. ADMIN no servidor (SecurityConfig:55). DTOs + mapeamento explícito impedem atribuir role/id/status em LeadService:15-26. Leituras públicas por ID exigem publicação; senha usa Principal. Sem multi-tenant.
A02 - Security Misconfiguration	Controles presentes; implantação pendente Actuator só health sem detalhes; container UID 10001; MySQL interno no Compose padrão. Prod exige cookie Secure, mas proxy precisa limpar headers Forwarded/X-Forwarded-* e impedir acesso direto. DB_URL pode conter TLS inadequado; configuração real não recebida.
A03 - Software Supply Chain Failures	Cobertura incompleta pom.xml e Dockerfile revistos. Parent Boot e SDK S3 fixados; imagens com tags mutáveis e sem digest/SBOM. Não foi resolvida a árvore Maven, rodado scanner CVE nem inspecionado JAR. Isso é pendência, não CVE atribuída sem evidência.
A04 - Cryptographic Failures	Sem falha nova verificada no código BCrypt custo 12; init usa fonte criptográfica; segredo inicial externo. TLS de banco/HTTPS/secret manager e backups só podem ser confirmados na nuvem.
A05 - Injection	Sem sink perigoso encontrado JPA derivado sem SQL concatenado. Não há execução de shell pelo servidor, XML recebido, eval, th:utext ou innerHTML. URLs de imagem restritas; textos escapados. Scripts locais são ferramentas do operador, não endpoints.
A06 - Insecure Design	OW-03 (média) Ausência de orçamento de GET e consultas públicas sem limite. DDoS volumétrico exige rede/CDN/provedor; o filtro da aplicação não o resolve sozinho.
A07 - Authentication Failures	OW-01 e OW-02 (médias) Controle por IP/instância sem conta e política aceita senha previsível. Sessão renovada ao autenticar; troca confere senha atual e expira sessões. MFA ausente, registrado como defesa adicional.
A08 - Software or Data Integrity Failures	Sem falha nova verificada; release pendente Jackson usa tipo explícito List<FieldDefinition>, sem default typing ou Java deserialization. Nomes/tipos/opções validados. Integridade/proveniência do artefato final ainda não verificada.
A09 - Security Logging and Alerting Failures	OW-04 (baixa) Logs de mutações não incluem ator; troca de senha sem evento explícito. Alertas e retenção da nuvem não recebidos.
A10 - Mishandling of Exceptional Conditions	Sem bypass verificado; testes dinâmicos pendentes Erros de formulário retornam view; objetos inexistentes/publicação inválida devolvem 404; upload acima do máximo tem 413. Stacktrace não é incluída na resposta. Falha S3/I/O pode virar 500 genérico: comportamento operacional a testar, sem retorno indevido demonstrado.

Tabela dos achados verificados

Base dos caminhos abreviados: src/main/java/br/com/escolhacerta/. Os trechos completos, condições e evidências estão na seção seguinte.

Severidade	Arquivo:linha	Descrição
MÉDIA	security/RateLimitFilter.java:17-17; security/RateLimitFilter.java:40-47; security/SecurityConfig.java:59-62	OW-01 - Login limita por IP, sem orçamento por conta compartilhado
MÉDIA	config/AdminBootstrap.java:21-27; controller/AdminController.java:176-183	OW-02 - Política aceita senhas administrativas previsíveis
MÉDIA	controller/PublicController.java:22-25; service/ContentService.java:17-18; repository/ContentRepository.java:6-8; controller/GlobalViewAdvice.java:14-18; security/RateLimitFilter.java:40-52	OW-03 - Leituras públicas carregam coleções sem limite e não têm quota de GET
BAIXA	service/ContentService.java:41-47; service/LeadService.java:34-40; service/FormService.java:49-50; controller/AdminController.java:182-193	OW-04 - Logs de mutações não identificam o administrador

Pontos fracos centrais

A autenticação depende apenas de senha, aceita valores previsíveis e não agrega tentativas por conta. O custo de leitura pública cresce com o acervo e o filtro não limita GETs. A trilha de mutações não identifica o administrador.

Condições e severidade

As severidades refletem o desenho confirmado no código, não um comprometimento observado. OW-01 depende de alternância de IP/instância; OW-02 depende de escolha de senha fraca; OW-03 depende de volume de acervo e tráfego para causar degradação; OW-04 prejudica a investigação de ações administrativas. Nenhum crítico/alto foi demonstrado.

Achados detalhados com evidência

OW-01 | Login limita por IP, sem orçamento por conta compartilhado

Severidade: MÉDIA | A07 - Authentication Failures

A única chave de quota contém getRemoteAddr e categoria. O username não participa do contador, e o HashMap é privado de cada instância. Trocar de IP ou de instância renova a quota para a mesma conta. Não foi identificado controle adicional de tentativas por conta.

Condições: Exige login acessível e múltiplos IPs, múltiplas instâncias ou reinício para exceder a quota local. Comprometer a conta ainda depende de acertar sua senha. Não demonstra login sem credenciais e não presume ataque já ocorrido.

Impacto: Permite ampliar tentativas contra um administrador além das 10/minuto por IP; cada senha existente avaliada consome BCrypt custo 12. Facilita guessing e credential stuffing.

Verificação: Código original de RateLimitFilter compilado contra stubs: mesma chave bloqueia a 11a tentativa; segundo IP e segunda instância recebem nova quota. Nenhuma autenticação real executada.

src/main/java/br/com/escolhacerta/security/RateLimitFilter.java:17-17

```
17:     private final Map<String, Window> windows = new HashMap<>();
```

src/main/java/br/com/escolhacerta/security/RateLimitFilter.java:40-47

```
40:         if ("POST".equals(req.getMethod())) {
41:             if (path.equals("/login")) category = "login";
42:             else if (path.equals("/orcamento") || path.equals("/sou-cuidador")
43:                 || path.equals("/contato") || path.startsWith("/formularios/")) category =
"public-forms";
44:             else if (path.equals("/admin/account")) category = "account";
45:             else if (path.equals("/admin/media")) { category = "upload"; limit = 5; }
46:         }
47:         if (category != null && !allowed(req.getRemoteAddr() + ":" + category, limit)) {
```

src/main/java/br/com/escolhacerta/security/SecurityConfig.java:59-62

```
59:         .formLogin(login -> login
60:             .loginPage("/login")
61:             .defaultSuccessUrl("/admin", true)
62:             .permitAll())
```

Recomendação: Manter quota por IP e adicionar controle por conta normalizada, compartilhado entre instâncias, com janela e backoff. Evitar bloqueio permanente que permita DoS da conta. Acrescentar MFA no CMS como defesa adicional.

OW-02 | Política aceita senhas administrativas previsíveis

Severidade: MÉDIA | A07 - Authentication Failures

Bootstrap e troca verificam comprimento mínimo 12 e limite 72 bytes, sem bloqueio de senhas comuns/comprometidas. A configuração contém somente autenticação por senha. As condições aceitam aaaaaaaaaa e 123456789012.

Condições: Só afeta uma conta se o operador escolher senha fraca; o script init gera senha aleatória forte. A troca exige administrador autenticado, senha atual correta e confirmação. Não há prova de que a senha real seja fraca.

Impacto: A política permite que uma credencial administrativa seja facilmente adivinhável, reduzindo a proteção contra tentativas automatizadas.

Verificação: Predicados extraídos literalmente das condições Java foram executados com Java 17. Ambos aceitaram os exemplos previsíveis. A troca completa e o bootstrap com banco não foram executados.

src/main/java/br/com/escolhacerta/config/AdminBootstrap.java:21-27

```
21: public void run(ApplicationArguments args) {
22:     if(repo.count()==0) {
23:         if(!email.matches("[^@\\s]+@[^@\\s]+\\.([^@\\s]+)"||password.length()<12||password.getBytes(
java.nio.charset.StandardCharsets.UTF_8).length>72)throw new IllegalArgumentException("Configure
ADMIN_EMAIL e ADMIN_PASSWORD com pelo menos 12 caracteres");
24:         AdminUser user=new AdminUser();
25:         user.setEmail(email.toLowerCase());
26:         user.setPasswordHash(encoder.encode(password));
27:         repo.save(user);
```

src/main/java/br/com/escolhacerta/controller/AdminController.java:176-183

```
176: @PostMapping("/account") public String password(@RequestParam String
currentPassword,@RequestParam String newPassword,@RequestParam String
confirmPassword,java.security.Principal principal,Model m,RedirectAttributes
flash,jakarta.servlet.http.HttpServletRequest request) {
177:     AdminUser user=users.findById(principal.getName()).orElseThrow();
178:     if(!encoder.matches(currentPassword,user.getPasswordHash())||newPassword.length()<12||newPas
sword.getBytes(java.nio.charset.StandardCharsets.UTF_8).length>72||!newPassword.equals(confirmPassword))
{
179:         m.addAttribute("error","Verifique a senha atual e use uma nova senha entre 12 e 72
caracteres, com confirmação igual.");
180:         return "admin/account";
181:     }
182:     user.setPasswordHash(encoder.encode(newPassword));
183:     users.save(user);
```

Recomendação: Usar serviço único de política em bootstrap/troca, mínimo de 15 caracteres para login sem MFA e lista de senhas comuns/comprometidas. Preservar limite de 72 bytes do BCrypt, aceitar passphrases e Unicode sem exigir composição artificial. Não enviar senhas em texto a serviços de verificação.

OW-03 | Leituras públicas carregam coleções sem limite e não têm quota de GET

Severidade: MÉDIA | A06 - Insecure Design / exaustão de recursos

A consulta published retorna List com todas as entidades, incluindo body. Na home, limit(3) é aplicado em stream depois da consulta, portanto não limita o SQL. O advice consulta os formulários publicados integralmente em cada handler MVC. O filtro só classifica POST e deixa os GET públicos sem quota. Não há cache de dados/resultado no código. Cache de templates não é cache dessas queries.

Condições: Visitantes podem repetir GET sem autenticação ou CSRF. A amplificação cresce conforme o acervo publicado e a concorrência. Saturação real, RPS suportado e indisponibilidade não foram medidos. Cache/WAF externo pode mitigar, mas não foi auditado.

Impacto: Trabalho de banco e alocação por requisição aumentam com o acervo; tráfego abusivo pode degradar CPU/RAM/latência em hospedagem pequena. Este é risco de DoS na camada de aplicação, não prova de proteção ou vulnerabilidade a DDoS volumétrico.

Verificação: Leitura integral dos fluxos e assinatura dos repositories comprova ausência de paginação/limite SQL. O filtro original deixou 100 GET /blog seguirem a cadeia sem bloqueio em teste isolado. Não houve teste de carga ou SQL real.

src/main/java/br/com/escolhacerta/controller/PublicController.java:22-25

```
22: @GetMapping("/") public String home(Model m) {
23:     m.addAttribute("services",content.published(ContentKind.SERVICE));
24:     m.addAttribute("posts",content.published(ContentKind.POST).stream().limit(3).toList());
25:     m.addAttribute("testimonials",content.published(ContentKind.TESTIMONIAL));
```

src/main/java/br/com/escolhacerta/service/ContentService.java:17-18

```
17: public java.util.List<Content> published(ContentKind kind) {
18:     return repo.findKindAndPublishedTrueOrderBySortOrderAscCreatedAtDesc(kind);
```

```

src/main/java/br/com/escolhacerta/repository/ContentRepository.java:6-8
6: public interface ContentRepository extends JpaRepository<Content, Long> {
7:     java.util.List<Content> findByKindAndPublishedTrueOrderBySortOrderAscCreatedAtDesc(ContentKind
kind);
8:     java.util.List<Content> findByKindOrderBySortOrderAscCreatedAtDesc(ContentKind kind);

src/main/java/br/com/escolhacerta/controller/GlobalViewAdvice.java:14-18
14: @ModelAttribute("site") public SiteSettings site() {
15:     return settings.findById(1L).orElse(new SiteSettings());
16: }
17: @ModelAttribute("publicForms") public java.util.List<CustomForm> forms() {
18:     return forms.findByPublishedTrueByIdDesc();

src/main/java/br/com/escolhacerta/security/RateLimitFilter.java:40-52
40:     if ("POST".equals(req.getMethod())) {
41:         if (path.equals("/login")) category = "login";
42:         else if (path.equals("/orcamento") || path.equals("/sou-cuidador")
43:             || path.equals("/contato") || path.startsWith("/formularios/")) category =
"public-forms";
44:         else if (path.equals("/admin/account")) category = "account";
45:         else if (path.equals("/admin/media")) { category = "upload"; limit = 5; }
46:     }
47:     if (category != null && !allowed(req.getRemoteAddr() + ":" + category, limit)) {
48:         res.setHeader("Retry-After", "60");
49:         res.sendError(429);
50:         return;
51:     }
52:     chain.doFilter(req, res);

```

Recomendação: Pagar listas públicas; buscar apenas os três posts da home no banco, usando projeção sem body; limitar e cachear o menu de formulários com invalidação no CMS. Definir orçamento de GET no ingresso e na aplicação, preservando health e assets.

OW-04 | Logs de mutações não identificam o administrador

Severidade: BAIXA | A09 - Security Logging and Alerting Failures

Eventos content_saved/content_deleted, lead_status_changed/lead_deleted e form_saved registram IDs e atributos, mas não o principal responsável. Troca de senha salva e invalida sessões sem evento explícito da aplicação. Não foi encontrado contexto MDC ou mecanismo de auditoria que adicione o autor.

Condições: Uma ação administrativa ocorre; a investigação usa os logs entregues pelo aplicativo. Logs adicionais de proxy, IAM ou SIEM podem existir na implantação e não foram inspecionados. O achado não afirma que não exista nenhum log na plataforma.

Impacto: A trilha da aplicação não permite atribuir com segurança mutações à conta responsável; dificulta investigar uso indevido de uma sessão ou mudança de senha.

Verificação: Busca em todo src/main e rastreamento dos pontos de log e da troca de senha. Sem evidência de execução ou coleta real de logs.

```

src/main/java/br/com/escolhacerta/service/ContentService.java:41-47
41: Content saved=repo.save(c);
42: log.info("content_saved id={ } kind={ } published={ }", saved.getId(), kind, saved.getPublished());
43: return saved;
44: }
45: public void delete(long id) {
46:     repo.delete(get(id));
47:     log.info("content_deleted id={ }", id);

src/main/java/br/com/escolhacerta/service/LeadService.java:34-40
34: public void status(long id, LeadStatus status) {
35:     get(id).setStatus(status);
36:     log.info("lead_status_changed id={ } status={ }", id, status);
37: }
38: public void delete(long id) {
39:     repo.delete(get(id));
40:     log.info("lead_deleted id={ }", id);

```

src/main/java/br/com/escolhacerta/service/FormService.java:49-50

```
49:         CustomForm saved=repo.save(f);
50:         log.info("form_saved id={} published={}", saved.getId(), saved.getPublished());
```

src/main/java/br/com/escolhacerta/controller/AdminController.java:182-193

```
182:         user.setPasswordHash(encoder.encode(newPassword));
183:         users.save(user);
184:         for (Object authenticated : sessions.getAllPrincipals()) {
185:             if (authenticated instanceof org.springframework.security.core.userdetails.UserDetails
details
186:                 && details.getUsername().equals(user.getEmail())) {
187:                 sessions.getAllSessions(authenticated, false).forEach(info -> info.expireNow());
188:             }
189:         }
190:         var currentSession = request.getSession(false);
191:         if (currentSession != null) currentSession.invalidate();
192:         org.springframework.security.core.context.SecurityContextHolder.clearContext();
193:         return "redirect:/login?passwordChanged";
```

Recomendação: Adicionar auditoria estruturada com ID da conta, ação, objeto, horário, resultado e correlation ID; registrar mudança de senha sem valor da senha/hash. Monitorar falhas de autenticação e eventos relevantes com proteção contra log flooding e dados pessoais desnecessários.

Controles corretos e verificações pendentes

Mass assignment

src/main/java/br/com/escolhacerta/controller/PublicController.java:71,91; dto/LeadForm.java:5-12; service/LeadService.java:15-26

Formulários recebem DTO, não entidade. ID/status/kind do lead não são escolhidos pelo navegador. Serviços criam Lead novo e copiam campos permitidos. DTOs do CMS contêm apenas atributos autorizados a ADMIN.

IDOR e acesso

src/main/java/br/com/escolhacerta/security/SecurityConfig.java:55; service/ContentService.java:26-29; controller/PublicController.java:86-92; controller/AdminController.java:176-178

Todos os handlers por ID foram rastreados. ADMIN global; publicados para visitantes; conta escolhida pelo Principal.

CSRF

src/main/java/br/com/escolhacerta/security/SecurityConfig.java:51-73;

src/main/resources/templates/fragments/layout.html:5; src/test/java/br/com/escolhacerta/ApplicationFlowTest.java:45-47

CSRF padrão mantido, sem disable/exceções. POSTs usam th:action e logout é POST. Teste MockMvc de token ausente existe, mas não foi executado.

Path traversal e upload

src/main/java/br/com/escolhacerta/storage/LocalMediaStorage.java:13-18; service/UploadService.java:13-29; config/WebConfig.java:10-11

Nome local é UUID; extensão vem de formato validado. Não usa original filename. Imagem é decodificada e regravada. Leitura pública de /media depende também da contenção de caminhos do handler Spring; testes HTTP com ../ e formas codificadas pendentes.

XSS

src/main/resources/templates/post.html:1; templates/admin/lead-detail.html:1; static/js/site.js:11-15;

src/main/java/br/com/escolhacerta/dto/ContentForm.java:9

Saída escapada e APIs DOM de texto; sem HTML/Markdown arbitrário. CSP script-src self sem unsafe-inline. javascript: em imagem é rejeitado no DTO.

SSRF

src/main/java/br/com/escolhacerta/storage/S3MediaStorage.java:14-25; dto/ContentForm.java:9

Não há fetch servidor de URL recebida do visitante/usuário. imageUrl é carregada pelo navegador.

Endpoint S3 vem de ambiente administrado, não de requisição pública.

Sessão

src/main/java/br/com/escolhacerta/security/SecurityConfig.java:63-66; controller/AdminController.java:184-192;

src/main/resources/application.yml:43-46; application-prod.yml:8-11

Migra sessão ao autenticar, uma sessão por conta, cookie HttpOnly/SameSite e Secure em prod; troca de senha expira sessões conhecidas. Funcionalidade completa ainda precisa do teste real.

Validação e consumo

src/main/java/br/com/escolhacerta/service/FormService.java:25-39,52-76; dto/FieldDefinition.java:5;

src/main/resources/application.yml:23-25,31-37

Até 20 perguntas; nomes reservados bloqueados; opções/select e respostas validados. Upload e requisição limitados; quota de POST existente. Não equivale a garantia contra DoS.

Riscos de implantação não contados como achados

application-prod.yml:7 habilita tratamento de headers encaminhados. O proxy confiável precisa remover headers externos e impedir acesso direto ao app; sem isso, a identidade usada pelo limite pode ser falsificada. Não recebemos o ingresso e não demonstramos essa configuração insegura. Da mesma forma, TLS da base, segurança do bucket e HTTPS precisam ser conferidos na plataforma.

Não se aplica ao produto atual

Contas de clientes/cuidadores, tenant, JWT, pagamentos, webhook, rich text e e-mails HTML não existem. Não foram forçados achados nessas funcionalidades ausentes. Sanitização de rich text será necessária se esse recurso for introduzido.

Provas de lógica e limites da execução

Executado com Java 17: RateLimitFilter original compilado contra stubs mínimos de Servlet/Spring; seus métodos foram invocados diretamente. As condições de senha foram extraídas literalmente dos arquivos. Isso não inicializa Spring, MySQL, CSRF ou HTTP e não simula DDoS.

```
PASS: tentativa 1 do primeiro IP aceita
PASS: tentativa 2 do primeiro IP aceita
PASS: tentativa 3 do primeiro IP aceita
PASS: tentativa 4 do primeiro IP aceita
PASS: tentativa 5 do primeiro IP aceita
PASS: tentativa 6 do primeiro IP aceita
PASS: tentativa 7 do primeiro IP aceita
PASS: tentativa 8 do primeiro IP aceita
PASS: tentativa 9 do primeiro IP aceita
PASS: tentativa 10 do primeiro IP aceita
PASS: 11a tentativa do mesmo IP bloqueada
PASS: outro IP recebe nova quota de login
PASS: outra instancia recebe quota independente
PASS: 100 GET /blog passam sem quota no filtro
PASS: bootstrap aceita 12 letras a repetidas
PASS: politica da troca aceita sequencia numerica de 12 caracteres com senha atual correta
LIMITACAO: stubs testam a logica do arquivo real; nao executam Spring, CSRF, HTTP ou banco.
```

Reproduzir

Na raiz do projeto: `python docs/security-audit/verify_security_logic.py`. Requer Python e JDK com compilador disponível por ToolProvider. O script cria arquivos temporários de stubs, compila apenas o filtro e imprime o resultado. Não altera o banco nem sobe o site. A ausência de Maven/Docker impediu a suíte integrada; não foram inventados resultados.

Antes da exposição pública

Rodar `mvn -B verify` e `smoke.py` em staging com base descartável; testar todas as rotas ADMIN com anônimo/USER, POST sem CSRF, rascunhos, campos extras `role/id/status`, `../` e variações codificadas, URLs perigosas, upload falso e expiração de sessões. Resolver dependências e rodar scanner SCA na release real. Testes de carga só em ambiente autorizado com limites definidos.

Cobertura de todos os handlers

Base: src/main/java/br/com/escolhacerta/controller/. Inventário completo e hashes dos 93 arquivos textuais da cópia permanecem em cobertura-auditoria.md e audit-data.json da auditoria anterior. O snapshot foi comparado e permaneceu intacto.

Método / rota	Handler:linha	Guarda / fluxo
GET /	PublicController.java:2 2	ContentService.java:17-18: consulta somente published=true.
GET /servicos, /blog, /depoimentos	PublicController.java:2 8	ContentService.java:17-18: consulta somente published=true.
GET /blog/{id}	PublicController.java:3 9	ContentService.java:26-29: published=true e kind=POST; caso contrário 404.
GET /sobre	PublicController.java:4 3	Página pública; não retorna registros privados.
GET /privacidade	PublicController.java:4 6	Página pública; não retorna registros privados.
GET /login	PublicController.java:4 9	Página pública; não retorna registros privados.
GET /orcamento, /sou-cuidador, /contato	PublicController.java:6 0	Página pública; não retorna registros privados.
POST /orcamento, /sou-cuidador, /contato	PublicController.java:6 8	Entrada pública @Valid LeadForm; cria registro novo; sem ID de lead fornecido.
GET /formularios/{id}	PublicController.java:7 8	PublicController.java:86-89: exige published=true. POST apenas cria lead; não altera formulário.
POST /formularios/{id}	PublicController.java:9 1	PublicController.java:86-89: exige published=true. POST apenas cria lead; não altera formulário.
GET /admin	AdminController.java: 38	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/contents/{kind}	AdminController.java: 45	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/contents/{kind}/new	AdminController.java: 50	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/contents/{kind}/{id}/edit	AdminController.java: 55	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa. Verificação de kind (Controller:57/79; Service:33).
POST /admin/contents/{kind}/save	AdminController.java: 70	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa. Verificação de kind (Controller:57/79; Service:33).

Método / rota	Handler:linha	Guarda / fluxo
POST /admin/contents/{kind}/{id}/delete	AdminController.java: 78	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa. Verificação de kind (Controller:57/79; Service:33).
GET /admin/leads	AdminController.java: 83	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/leads/{id}	AdminController.java: 89	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/leads/{id}/status	AdminController.java: 93	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/leads/{id}/delete	AdminController.java: 97	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/forms	AdminController.java: 101	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/forms/new	AdminController.java: 105	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/forms/{id}/edit	AdminController.java: 111	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/forms/save	AdminController.java: 122	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/forms/{id}/delete	AdminController.java: 134	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/settings	AdminController.java: 138	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/settings	AdminController.java: 149	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/media	AdminController.java: 161	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/media	AdminController.java: 164	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
GET /admin/account	AdminController.java: 173	ADMIN no servidor (SecurityConfig.java:55); escopo global da empresa.
POST /admin/account	AdminController.java: 176	ADMIN; conta obtida do Principal, senha atual conferida (176-178); invalida sessões (184-192).

Outros handlers: login/logout e Actuador em SecurityConfig:56-63; recursos /media em WebConfig:10-11; advice público em GlobalViewAdvice:14-18; upload excessivo em ErrorAdvice:8-10. Todos revisitados.

Recomendações e referências

Prioridade	Ação / aceite resumido
P1 OW-01	Quota por conta compartilhada + IP, backoff/TTL, testes com IPs e instâncias distintos.
P1 OW-02	Política única, mínimo apropriado sem MFA, blocklist e testes em bootstrap/troca.
P2 OW-03	Limite SQL, projeções, paginação, cache com invalidação e quota de GET. Medir carga em staging.
P2 OW-04	Ator + ação + objeto + resultado + correlation ID; mudança de senha auditada sem segredos.
P1 implantação	Confirmar proxy confiável, HTTPS, profile prod, TLS de banco e ingress/WAF. Não confirmado nesta auditoria.
P3 cadeia de software	Scanner SCA/SBOM, histórico completo e inspeção do JAR; fixar digests conforme política de release.

<https://top10.owasp.org/2025/>
https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
https://cheatsheetseries.owasp.org/cheatsheets/Denial_of_Service_Cheat_Sheet.html
https://cheatsheetseries.owasp.org/cheatsheets/Mass_Assignment_Cheat_Sheet.html
<https://docs.spring.io/spring-security/reference/servlet/exploits/csrf.html>
<https://docs.spring.io/spring/reference/web/webmvc/filters.html>
O OWASP Top 10 é referência de riscos; não é uma lista exaustiva ou um certificado. A versão 2025 foi consultada para esta revisão. As recomendações de correção são propostas para esta stack e precisam ser verificadas após implementação.

ISSUES PARA O GITHUB

Quatro issues acionáveis. O texto completo está também em issues-owasp.md para cópia sem quebras visuais do PDF. A próxima implementação deve atender os critérios de aceite e repetir a verificação.

--- ISSUE 1 ---

[Segurança] Login limita por IP, sem orçamento por conta compartilhado

Labels sugeridas: security, média

Problema

A única chave de quota contém getRemoteAddr e categoria. O username não participa do contador, e o HashMap é privado de cada instância. Trocar de IP ou de instância renova a quota para a mesma conta. Não foi identificado controle adicional de tentativas por conta.

Condições de exploração

Exige login acessível e múltiplos IPs, múltiplas instâncias ou reinício para exceder a quota local. Comprometer a conta ainda depende de acertar sua senha. Não demonstra login sem credenciais e não presume ataque já ocorrido.

Evidência

src/main/java/br/com/escolhacerta/security/RateLimitFilter.java:17-17

```
17:     private final Map<String, Window> windows = new HashMap<>();
```

src/main/java/br/com/escolhacerta/security/RateLimitFilter.java:40-47

```
40:         if ("POST".equals(req.getMethod())) {
41:             if (path.equals("/login")) category = "login";
42:             else if (path.equals("/orcamento") || path.equals("/sou-cuidador")
43:                 || path.equals("/contato") || path.startsWith("/formularios/")) category =
"public-forms";
44:             else if (path.equals("/admin/account")) category = "account";
45:             else if (path.equals("/admin/media")) { category = "upload"; limit = 5; }
46:         }
47:         if (category != null && !allowed(req.getRemoteAddr() + ":" + category, limit)) {
```

src/main/java/br/com/escolhacerta/security/SecurityConfig.java:59-62

```
59:         .formLogin(login -> login
60:             .loginPage("/login")
61:             .defaultSuccessUrl("/admin", true)
62:             .permitAll())
```

Impacto

Permite ampliar tentativas contra um administrador além das 10/minuto por IP; cada senha existente avaliada consome BCrypt custo 12. Facilita guessing e credential stuffing.

Sugestão de correção

Manter quota por IP e adicionar controle por conta normalizada, compartilhado entre instâncias, com janela e backoff. Evitar bloqueio permanente que permita DoS da conta. Acrescentar MFA no CMS como defesa adicional.

Critérios de aceite

- [] A mesma conta continua limitada ao alternar IPs e instâncias.
- [] A quota por IP permanece e o e-mail não é armazenado sem necessidade em logs.

- [] O bloqueio tem recuperação e TTL definidos; não permite bloqueio permanente malicioso.
- [] Teste de integração valida limites usando login real com CSRF.

--- FIM ISSUE 1 ---

--- ISSUE 2 ---

[Segurança] Política aceita senhas administrativas previsíveis

Labels sugeridas: security, média

Problema

Bootstrap e troca verificam comprimento mínimo 12 e limite 72 bytes, sem bloqueio de senhas comuns/comprometidas. A configuração contém somente autenticação por senha. As condições aceitam aaaaaaaaaa e 123456789012.

Condições de exploração

Só afeta uma conta se o operador escolher senha fraca; o script init gera senha aleatória forte. A troca exige administrador autenticado, senha atual correta e confirmação. Não há prova de que a senha real seja fraca.

Evidência

src/main/java/br/com/escolhacerta/config/AdminBootstrap.java:21-27

```
21: public void run(ApplicationArguments args) {
22:     if(repo.count()==0) {
23:         if(!email.matches("[^@\\s]+@[^@\\s]+\\.([^@\\s]+)" || password.length()<12 || password.getBytes(
java.nio.charset.StandardCharsets.UTF_8).length>72) throw new IllegalStateException("Configure
ADMIN_EMAIL e ADMIN_PASSWORD com pelo menos 12 caracteres");
24:         AdminUser user=new AdminUser();
25:         user.setEmail(email.toLowerCase());
26:         user.setPasswordHash(encoder.encode(password));
27:         repo.save(user);
```

src/main/java/br/com/escolhacerta/controller/AdminController.java:176-183

```
176: @PostMapping("/account") public String password(@RequestParam String
currentPassword,@RequestParam String newPassword,@RequestParam String
confirmPassword,java.security.Principal principal,Model m,RedirectAttributes
flash,jakarta.servlet.http.HttpServletRequest request) {
177:     AdminUser user=users.findByEmail(principal.getName()).orElseThrow();
178:     if(!encoder.matches(currentPassword,user.getPasswordHash()) || newPassword.length()<12 || newPas
sword.getBytes(java.nio.charset.StandardCharsets.UTF_8).length>72 || !newPassword.equals(confirmPassword))
{
179:         m.addAttribute("error","Verifique a senha atual e use uma nova senha entre 12 e 72
caracteres, com confirmação igual.");
180:         return "admin/account";
181:     }
182:     user.setPasswordHash(encoder.encode(newPassword));
183:     users.save(user);
```

Impacto

A política permite que uma credencial administrativa seja facilmente adivinhável, reduzindo a proteção contra tentativas automatizadas.

Sugestão de correção

Usar serviço único de política em bootstrap/troca, mínimo de 15 caracteres para login sem MFA e lista de senhas comuns/comprometidas. Preservar limite de 72 bytes do BCrypt, aceitar passphrases e Unicode sem exigir composição artificial. Não enviar senhas em texto a serviços de verificação.

Critérios de aceite

- [] Bootstrap e troca rejeitam os dois exemplos e senhas da blocklist.
- [] A mesma política é aplicada nos dois fluxos, com mensagens coerentes.
- [] Senhas fortes e passphrases dentro do limite de bytes são aceitas.
- [] Nenhuma senha ou hash é registrado em logs.

--- FIM ISSUE 2 ---

--- ISSUE 3 ---

[Segurança] Leituras públicas carregam coleções sem limite e não têm quota de GET

Labels sugeridas: security, média

Problema

A consulta published retorna List com todas as entidades, incluindo body. Na home, limit(3) é aplicado em stream depois da consulta, portanto não limita o SQL. O advice consulta os formulários publicados integralmente em cada handler MVC. O filtro só classifica POST e deixa os GET públicos sem quota. Não há cache de dados/resultado no código. Cache de templates não é cache dessas queries.

Condições de exploração

Visitantes podem repetir GET sem autenticação ou CSRF. A amplificação cresce conforme o acervo publicado e a concorrência. Saturação real, RPS suportado e indisponibilidade não foram medidos. Cache/WAF externo pode mitigar, mas não foi auditado.

Evidência

src/main/java/br/com/escolhacerta/controller/PublicController.java:22-25

```
22: @GetMapping("/") public String home(Model m) {
23:     m.addAttribute("services",content.published(ContentKind.SERVICE));
24:     m.addAttribute("posts",content.published(ContentKind.POST).stream().limit(3).toList());
25:     m.addAttribute("testimonials",content.published(ContentKind.TESTIMONIAL));
```

src/main/java/br/com/escolhacerta/service/ContentService.java:17-18

```
17: public java.util.List<Content> published(ContentKind kind) {
18:     return repo.findByKindAndPublishedTrueOrderBySortOrderAscCreatedAtDesc(kind);
```

src/main/java/br/com/escolhacerta/repository/ContentRepository.java:6-8

```
6: public interface ContentRepository extends JpaRepository<Content,Long> {
7:     java.util.List<Content> findByKindAndPublishedTrueOrderBySortOrderAscCreatedAtDesc(ContentKind
kind);
8:     java.util.List<Content> findByKindOrderBySortOrderAscCreatedAtDesc(ContentKind kind);
```

src/main/java/br/com/escolhacerta/controller/GlobalViewAdvice.java:14-18

```
14: @ModelAttribute("site") public SiteSettings site() {
15:     return settings.findById(1L).orElse(new SiteSettings());
16: }
17: @ModelAttribute("publicForms") public java.util.List<CustomForm> forms() {
18:     return forms.findByPublishedTrueOrderByIdDesc();
```

src/main/java/br/com/escolhacerta/security/RateLimitFilter.java:40-52

```

40:         if ("POST".equals(req.getMethod())) {
41:             if (path.equals("/login")) category = "login";
42:             else if (path.equals("/orcamento") || path.equals("/sou-cuidador")
43:                 || path.equals("/contato") || path.startsWith("/formularios/")) category =
"public-forms";
44:             else if (path.equals("/admin/account")) category = "account";
45:             else if (path.equals("/admin/media")) { category = "upload"; limit = 5; }
46:         }
47:         if (category != null && !allowed(req.getRemoteAddr() + ":" + category, limit)) {
48:             res.setHeader("Retry-After", "60");
49:             res.sendError(429);
50:             return;
51:         }
52:         chain.doFilter(req, res);

```

Impacto

Trabalho de banco e alocação por requisição aumentam com o acervo; tráfego abusivo pode degradar CPU/RAM/latência em hospedagem pequena. Este é risco de DoS na camada de aplicação, não prova de proteção ou vulnerabilidade a DDoS volumétrico.

Sugestão de correção

Paginar listas públicas; buscar apenas os três posts da home no banco, usando projeção sem body; limitar e cachear o menu de formulários com invalidação no CMS. Definir orçamento de GET no ingresso e na aplicação, preservando health e assets.

Critérios de aceite

- [] A consulta da home tem limite no banco e não carrega o corpo de todos os posts.
- [] Listagens possuem tamanho máximo por página e não retornam todo o acervo.
- [] Advice usa lista limitada/cacheada com invalidação ao publicar ou editar.
- [] Teste em staging mede latência/RAM com acervo representativo e limites de GET.

--- FIM ISSUE 3 ---

--- ISSUE 4 ---

[Segurança] Logs de mutações não identificam o administrador

Labels sugeridas: security, baixa

Problema

Eventos content_saved/content_deleted, lead_status_changed/lead_deleted e form_saved registram IDs e atributos, mas não o principal responsável. Troca de senha salva e invalida sessões sem evento explícito da aplicação. Não foi encontrado contexto MDC ou mecanismo de auditoria que adicione o autor.

Condições de exploração

Uma ação administrativa ocorre; a investigação usa os logs entregues pelo aplicativo. Logs adicionais de proxy, IAM ou SIEM podem existir na implantação e não foram inspecionados. O achado não afirma que não exista nenhum log na plataforma.

Evidência

src/main/java/br/com/escolhacerta/service/ContentService.java:41-47

```
41:         Content saved=repo.save(c);
42:         log.info("content_saved id={} kind={} published={}", saved.getId(), kind, saved.getPublished());
43:         return saved;
44:     }
45:     public void delete(long id) {
46:         repo.delete(get(id));
47:         log.info("content_deleted id={}", id);
```

src/main/java/br/com/escolhacerta/service/LeadService.java:34-40

```
34:     public void status(long id, LeadStatus status) {
35:         get(id).setStatus(status);
36:         log.info("lead_status_changed id={} status={}", id, status);
37:     }
38:     public void delete(long id) {
39:         repo.delete(get(id));
40:         log.info("lead_deleted id={}", id);
```

src/main/java/br/com/escolhacerta/service/FormService.java:49-50

```
49:     CustomForm saved=repo.save(f);
50:     log.info("form_saved id={} published={}", saved.getId(), saved.getPublished());
```

src/main/java/br/com/escolhacerta/controller/AdminController.java:182-193

```
182:         user.setPasswordHash(encoder.encode(newPassword));
183:         users.save(user);
184:         for (Object authenticated : sessions.getAllPrincipals()) {
185:             if (authenticated instanceof org.springframework.security.core.userdetails.UserDetails
details
186:                 && details.getUsername().equals(user.getEmail())) {
187:                 sessions.getAllSessions(authenticated, false).forEach(info -> info.expireNow());
188:             }
189:         }
190:         var currentSession = request.getSession(false);
191:         if (currentSession != null) currentSession.invalidate();
192:         org.springframework.security.core.context.SecurityContextHolder.clearContext();
193:         return "redirect:/login?passwordChanged";
```

Impacto

A trilha da aplicação não permite atribuir com segurança mutações à conta responsável; dificulta investigar uso indevido de uma sessão ou mudança de senha.

Sugestão de correção

Adicionar auditoria estruturada com ID da conta, ação, objeto, horário, resultado e correlation ID; registrar mudança de senha sem valor da senha/hash. Monitorar falhas de autenticação e eventos relevantes com proteção contra log flooding e dados pessoais desnecessários.

Critérios de aceite

- [] Mutações registram ator autenticado e objeto, com correlation ID.
- [] Alteração de senha emite evento sem senha, hash ou token.
- [] Os eventos ficam disponíveis para revisão com retenção e acesso definidos.
- [] Teste confirma autor correto e ausência de segredos nos logs.

--- FIM ISSUE 4 ---